
Mariana BS - Cybersecurity Engineer
GUIA COMPLETO DE ESTUDOS
Analista SOC N1
LINUX TAMBÉM CONTA HISTÓRIA
Processos e Serviços
$ ps aux | grep suspicious
root 4821 0.3 python3 ...
www-data 5178 1.2 /usr/bin/...
$ systemctl status sshd
sshd.service - OpenSSH
Logs e Evidências
$ tail -f /var/log/auth.log
Oct 24 10:15:23 sshd: Failed password for invalid user admin from 192.168.1.66
Oct 24 10:15:28 sshd: Accepted password for analyst from 10.0.0.25
Autenticação e Acessos
SSH (22)
sudo
su
/etc/passwd /etc/shadow
Investigação no Linux
$ last
$ journalctl -u sshd
$ grep -R "powershell" /
$ find / -type f -mnin -60
$ ss -tulpn
$ auditctl -l
Estrutura e Pontos-Chave
/var/log Logs do sistema
/etc Configurações críticas
/home Usuários
/proc Processos em tempo real
/systemd Serviços e inicialização
Tópicos do Módulo
Processos e serviços
Autenticação e usuários
Logs (syslog, journal, auth)
Permissões e integridade
Rede e conexões
Comandos essenciais
Detecção de atividades suspeitas
Triagem N1 no Linux
SOC N1
NÃO É SÓ sudo E apt-get
LINUX PARA SOC
PROCESSOS E SERVIÇOS
LOGS E JOURNALD
AUTENTICAÇÃO (SSH/SUDO)
PERMISSÕES E INTEGRIDADE
REDE E CONEXÕES
TRIAGEM E INVESTIGAÇÃO
LINUX
Plano de Estudo – Módulo 4
Entender a estrutura do Linux
Analisar logs e autenticação
Investigar processos e serviços
Identificar atividade suspeita
Praticar triagem N1
Módulo 4 — Linux para SOC
Do processo ao log, da autenticação ao serviço: como investigar Linux sem confundir administração legítima com incidente.
Você vai aprender a:
Ler e interpretar os principais logs do Linux.
Analisar processos, serviços e conexões.
Investigar acessos, permissões e uso de contas.
Identificar sinais de comprometimento.
Realizar uma triagem N1 baseada em evidências.
Público:
Iniciante que quer lidar com Linux na prática, focando em investigação e operação de SOC.
Pré-requisitos:
Módulo 1 (Redes)
Módulo 2 (Arquitetura de Ambientes Corporativos)
Módulo 3 (Windows para SOC)

Sumário

Módulo 4: Linux para SOC 4
O que vc vai aprender 4
Método de estudo 4
Regras comuns a todos os capítulos 5
Contexto e cuidado antes de concluir 5
Leitura de SOC: o que vale para todos os temas 5
Logs simulados 5
Pergunta de revisão (para todos os capítulos) 5
Os dois fluxos de correlação usados no módulo 6
Os 24 capítulos 7
4.01 Mapa mental do Linux no SOC 7
4.02 Terminal e navegação defensiva 7
4.03 Sistema de arquivos e FHS 8
4.04 Usuários, grupos e privilégios 9
4.05 Permissões e ACL 10
4.06 Processos e árvore de execução 10
4.07 Processos, memória e arquivos abertos 11
4.08 systemd e ciclo de serviços 12
4.09 Tarefas cron e timers 12
4.10 Autenticação Linux e PAM 13
4.11 SSH e authorized_keys 14
4.12 Logs de sistema e journald 15
4.13 Consultas e correlação temporal 15
4.14 Rede Linux para SOC 16
4.15 DNS e resolução 17
4.16 Pacotes e integridade 17
4.17 Persistência e alterações de inicialização 18
4.18 Ferramentas de visibilidade e auditoria 19
4.19 Containers e Linux 20
4.20 Servidor web e aplicações 20
4.21 Cloud Linux e agentes 21
4.22 Malware Linux e indicadores 22
4.23 Triagem ponta a ponta 22
4.24 Handover, entrevistas e rotina 23
Laboratórios 25
Roteiro comum dos 10 laboratórios 25
Os laboratórios 25
Casos práticos 28

Roteiro comum dos 8 casos 28
Os casos 28
Fechamento do Módulo 4 30
Falsos positivos recorrentes: como confirmar 30
Entrevistas SOC N1: resposta fraca x resposta boa 30
Exercícios de fixação 31
Checklist de domínio 32
Cheat sheet Linux para SOC N1 32
Respostas comentadas 32
Fontes e aprofundamento 33
Próximo módulo 33

Módulo 4: Linux para SOC

> **NA VIDA REAL**
> Linux não é aquela tela preta que faz hacker parecer inteligente no cinema. É produção, é banco, é container, é serviço crítico e às vezes é o único servidor que ninguém ousa reiniciar desde 2022.

O que vc vai aprender

- Identificar processos, privilégios, serviços, conexões e evidências de execução.
- Investigar SSH, sudo, systemd, cron, journald e auditd com leitura contextual.
- Diferenciar mudança administrativa, suspeita e comprometimento confirmado.
- Produzir tickets, linhas do tempo e escalonamentos verificáveis.

Método de estudo

24 capítulos técnicos em duas páginas de estudo aplicado, seguidos de laboratórios, casos, exercícios e referências. Cada capítulo traz conceitos, comandos apenas de observação, tabela de Leitura de SOC, log simulado, decisão N1 e pergunta de revisão.

Bloco do capítulo	Para que serve
O que é	Os elementos do tema
Caixa do N1	O modelo mental do tema: o que procurar, em uma frase
Leitura de SOC	Cenário típico, investigação N1 e limitação da telemetria
Comandos e log simulado	Consultas somente de observação e exercício de leitura de evidência
Na vida real	O lembrete prático do tema
Regras comuns	O que vale para todos os capítulos fica numa seção única, logo abaixo

Regras comuns a todos os capítulos

> **O QUE UM N1 REALMENTE PRECISA SABER: Por que cada tema importa**
> Em SOC N1, o trabalho não é decorar a sintaxe de um comando, e sim conectar o comportamento observado à função do ativo, à conta que o executou e ao impacto potencial.

Os 24 capítulos seguem o mesmo raciocínio. Para não repetir o mesmo texto em cada um, o que vale para todos está aqui, uma vez. Cada capítulo traz apenas o que é específico do seu tema.

Contexto e cuidado antes de concluir

Aspecto	Regra
Contexto esperado	Verifique inventário, papel do host, software aprovado, janela de mudança e histórico recente antes de concluir.
Ponto de atenção	Os exemplos variam entre Debian/Ubuntu e RHEL/Fedora; versão, privilégios e configuração alteram os resultados.
Antes de executar comandos	Confirme o sistema, permissões e escopo autorizado. Os comandos são demonstrativos e alguns podem não existir ou retornar vazio, dependendo da distribuição.

Leitura de SOC: o que vale para todos os temas

Pergunta da triagem	Leitura prática
O que pode ser suspeito?	Desvio do padrão do host, ausência de autorização, alteração recente sensível ou efeitos externos sem justificativa.
Quando escalo?	Se houver privilégio elevado, persistência não autorizada, execução correlacionada, comunicação maliciosa ou impacto em ativo crítico.
Conclusão defensável	A ocorrência exige validação contextual; não afirme execução maliciosa, exfiltração ou comprometimento sem telemetria que sustente a conclusão.

Logs simulados

Cada capítulo traz uma linha de log no formato abaixo. **Log fictício para treino.** Não representa formato nativo de journald, syslog ou auditd. Use o campo source para achar o registro verdadeiro e valide timestamp, PID, UID, host e evidências correlatas. O ID de mudança acima é ilustrativo, não comprova autorização.

Pergunta de revisão (para todos os capítulos)

> **DICA**

> Ao terminar cada capítulo, responda: qual evidência independente faria vc mudar sua hipótese? Registre fonte, horário, host e limitação.

> **NA VIDA REAL**
> Vale para todos os casos deste módulo: o ambiente não lê o PowerPoint da arquitetura, e o log não assina confissão.

Os dois fluxos de correlação usados no módulo



Figura 4.1: Do alerta à decisão



Figura 4.2: Da identidade ao SIEM

Os 24 capítulos

4.01 Mapa mental do Linux no SOC

O que é: Kernel, espaço de usuário, shell, processos e distribuição.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Um alerta de processo só tem sentido quando associado ao host, usuário, comando e papel do servidor.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Servidor de aplicação reiniciou após manutenção; agent reporta novo processo.
Investigação N1 (próximo passo)	Compare janela de mudança, boot ID, pai do processo e horário.
Limitação da telemetria	Kernel, init e aplicações são camadas diferentes. Distribuições variam em caminhos, pacotes e convenções.

Comandos de consulta no laboratório

```
uname -a
cat /etc/os-release
hostnamectl
```

Log simulado

```
2026-10-31T10:01:12-03:00 srv-app-01 soc-training[1001]: source=linux-lab category="Mapa
mental do Linux no SOC" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Não trate serviço reiniciado como comprometimento sem ações adicionais.

4.02 Terminal e navegação defensiva

O que é: Pwd, cd, ls, file, stat, find e leitura cuidadosa.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Nome e extensão não identificam o conteúdo real; metadados precisam de contexto.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Arquivo recém-criado em /tmp recebe nome parecido com binário de sistema.
Investigação N1 (próximo passo)	Registre inode, dono, modo, caminho, assinatura de pacote e processo associado.
Limitação da telemetria	Leia primeiro. Evite comandos que alteram permissões ou removem arquivos em produção.

Comandos de consulta no laboratório

```
pwd
ls -la /etc
stat /etc/passwd
file /bin/bash
```

Log simulado

```
2026-10-31T10:02:12-03:00 srv-app-01 soc-training[1002]: source=linux-lab category="Terminal e navegação defensiva" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Diretório temporário é pista, não veredito.

4.03 Sistema de arquivos e FHS

O que é: /etc, /var, /proc, /sys, /run, /tmp, /home, /usr e /opt.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> O mesmo arquivo pode estar em partição, overlay ou volume remoto.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Um executável em /tmp aparece na lista de processos.
Investigação N1 (próximo passo)	Cruze /proc/PID/exe, mount namespace, hashes e histórico de criação.
Limitação da telemetria	Mounts, containers e symlinks alteram a interpretação de caminhos.

Comandos de consulta no laboratório

```
findmnt
df -hT
ls -ld /tmp /var/log /etc
```

Log simulado

```
2026-10-31T10:03:12-03:00 srv-app-01 soc-training[1003]: source=linux-lab category="Sistema de arquivos e FHS" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Um caminho dentro de container não equivale ao caminho do host.

4.04 Usuários, grupos e privilégios

O que é: Uid, gid, root, sudo, su, contas de serviço.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> UID 0 implica privilégios máximos dentro do respectivo contexto de namespace.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Conta de serviço executa sudo fora da janela de manutenção.
Investigação N1 (próximo passo)	Busque usuário, tty, comando, PAM, sudo logs e ticket.
Limitação da telemetria	Nome root não prova ausência de isolamento; confira contexto do container.

Comandos de consulta no laboratório

```
id
getent passwd
getent group sudo
sudo -l
```

Log simulado

```
2026-10-31T10:04:12-03:00 srv-app-01 soc-training[1004]: source=linux-lab category="Usuários, grupos e privilégios" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> sudo não é automaticamente exploração.

4.05 Permissões e ACL

O que é: Rwx, ownership, umask, setuid, setgid, sticky bit e getfacl.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Permissão ampla em arquivos sensíveis amplia superfície; nem toda permissão ampla é incidente.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Script em pasta de deploy fica executável por todos.
Investigação N1 (próximo passo)	Compare padrão do pipeline, owner e últimos changes.
Limitação da telemetria	Cheque ACL efetiva, montagem noexec e proprietário antes de concluir.

Comandos de consulta no laboratório

```
stat -c "%a %U %G %n" /etc/passwd
getfacl /tmp
```

Log simulado

```
2026-10-31T10:05:12-03:00 srv-app-01 soc-training[1005]: source=linux-lab category="Permissões
e ACL" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Não altere permissões durante triagem N1.

4.06 Processos e árvore de execução

O que é: Pid, ppid, argv, environment, procfs, estados.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Árvore de processos expressa relação, não intenção; PIDs são reciclados.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	nginx inicia shell em horário incomum.
Investigação N1 (próximo passo)	Validar worker, script de saúde, processo filho e chamadas seguintes.
Limitação da telemetria	Correlacione boot ID, start time, executable path, sessão e hash.

Comandos de consulta no laboratório

```
ps -eo pid,ppid,user,etime,cmd --forest | head -40
pstree -ap
```

Log simulado

```
2026-10-31T10:06:12-03:00 srv-app-01 soc-training[1006]: source=linux-lab category="Processos
e árvore de execução" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Um processo filho incomum merece apuração, não conclusão antecipada.

4.07 Processos, memória e arquivos abertos

O que é: /proc, lsof, fuser, cwd e descritores.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Arquivo deletado ainda aberto pode persistir em memória até a liberação do descritor.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Serviço consome CPU e mantém arquivo deleted aberto.
Investigação N1 (próximo passo)	Observe binário, atualização pendente, rota de execução e métricas.
Limitação da telemetria	Permissões, containers e hidepid limitam visão.

Comandos de consulta no laboratório

```
ps aux --sort=-%mem | head
lsof -p 1 | head
```

Log simulado

```
2026-10-31T10:07:12-03:00 srv-app-01 soc-training[1007]: source=linux-lab category="Processos, memória e arquivos abertos" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> CPU alta sozinha não prova mineração.

4.08 systemd e ciclo de serviços

O que é: Units, targets, journal, enable e start.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Serviço enabled não significa active; arquivo unit pode ter overrides.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Serviço de nome genérico aparece habilitado após incidente.
Investigação N1 (próximo passo)	Inspecione ExecStart, User, caminho e drop-ins, sem alterar a unit.
Limitação da telemetria	systemctl cat, show e journalctl complementam a leitura.

Comandos de consulta no laboratório

```
systemctl status ssh --no-pager
systemctl list-unit-files --type=service | head
```

Log simulado

```
2026-10-31T10:08:12-03:00 srv-app-01 soc-training[1008]: source=linux-lab category="systemd e ciclo de serviços" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Atenção a serviço novo com binário fora da árvore esperada.

4.09 Tarefas cron e timers

O que é: Crontab, /etc/cron.d e systemd timers.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Agendamento legítimo e persistência compartilham mecanismo.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Tarefa a cada cinco minutos executa script em /opt.
Investigação N1 (próximo passo)	Verifique owner, arquivo-alvo, package owner, change e conexões.
Limitação da telemetria	Crons de sistema e de usuário usam locais diferentes; logs variam.

Comandos de consulta no laboratório

```
crontab -l
systemctl list-timers --all
```

Log simulado

```
2026-10-31T10:09:12-03:00 srv-app-01 soc-training[1009]: source=linux-lab category="Tarefas
cron e timers" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> O período sozinho não comprova beaconing.

4.10 Autenticação Linux e PAM

O que é: Sshd, login, sudo, pam, faillock e sessões.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Falha, aceitação e sessão concluída são estados distintos.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Várias falhas SSH são seguidas de Accepted publickey.
Investigação N1 (próximo passo)	Correlacione origem, fingerprint da chave, usuário e ações posteriores.
Limitação da telemetria	lastb depende de btmp; logs podem faltar ou estar rotacionados.

Comandos de consulta no laboratório

```
last -a | head
lastb -a | head
who
journalctl -u ssh --since today
```

Log simulado

```
2026-10-31T10:10:12-03:00 srv-app-01 soc-training[1010]: source=linux-lab
category="Autenticação Linux e PAM" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Não reporte invasão por tentativas bloqueadas.

4.11 SSH e authorized_keys

O que é: Chaves públicas, sshd_config, jump host e bastion.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Chave nova precisa de contexto: foi aprovada, de quem é e onde é usada?

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Chave adicionada para conta privilegiada sem alteração conhecida.
Investigação N1 (próximo passo)	Preserve conteúdo, metadados e origem de acesso; escale conforme playbook.
Limitação da telemetria	Config efetiva pode depender de Include/Match; não edite no plantão.

Comandos de consulta no laboratório

```
sshd -T 2>/dev/null | head
ls -la ~/.ssh
stat ~/.ssh/authorized_keys
```

Log simulado

```
2026-10-31T10:11:12-03:00 srv-app-01 soc-training[1011]: source=linux-lab category="SSH e
authorized_keys" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
> Não copie chaves privadas nem divulgue segredos em tickets.

4.12 Logs de sistema e journald

O que é: Journald, syslog, rsyslog, arquivos e persistência.

> **O QUE UM N1 REALMENTE PRECISA SABER**
> Ausência em /var/log não significa ausência no journal.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	SIEM para de receber logs mas host segue operando.
Investigação N1 (próximo passo)	Verifique collector, backlog, clock, logs locais e política de retenção.
Limitação da telemetria	Rotação, volátil vs persistente e forwarding influenciam visibilidade.

Comandos de consulta no laboratório

```
journalctl -b -n 30 --no-pager
journalctl --list-boots
```

Log simulado

```
2026-10-31T10:12:12-03:00 srv-app-01 soc-training[1012]: source=linux-lab category="Logs de sistema e journald" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
> Falta de telemetria é lacuna, não inocência.

4.13 Consultas e correlação temporal

O que é: Grep, awk, sed, sort, uniq e timestamps.

> **O QUE UM N1 REALMENTE PRECISA SABER**
> Linha do tempo exige timezone, boot id, host e múltiplas fontes.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Suspeita de execução às 03:12 com eventos em UTC e local.
Investigação N1 (próximo passo)	Normalize timestamps e compare processo, auth e firewall.
Limitação da telemetria	Cuidado com grep em logs binários, campos multiline e locale.

Comandos de consulta no laboratório

```
journalctl --since "1 hour ago" --no-pager | tail -30
```

Log simulado

```
2026-10-31T10:13:12-03:00 srv-app-01 soc-training[1013]: source=linux-lab category="Consultas
e correlação temporal" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Eventos próximos não provam causalidade.

4.14 Rede Linux para SOC

O que é: Ip, ss, resolvectl, routing, firewall e namespaces.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Socket estabelecido não revela sozinho processo malicioso ou conteúdo.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Servidor inicia saída HTTPS para IP pouco usual.
Investigação N1 (próximo passo)	Mapeie PID, DNS, proxy, egress permitido e mudança.
Limitação da telemetria	ss pode ocultar PID sem permissões; conexões curtas desaparecem.

Comandos de consulta no laboratório

```
ip -br addr
ip route
ss -tupn
resolvectl status
```

Log simulado

```
2026-10-31T10:14:12-03:00 srv-app-01 soc-training[1014]: source=linux-lab category="Rede Linux para SOC" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> IP raro não significa IOC por si só.

4.15 DNS e resolução

O que é: Resolv.conf, nss, systemd-resolved, cache e consultas.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Resolução DNS e conexão TCP são eventos diferentes.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Série de NXDOMAIN ocorre após deploy de aplicação.
Investigação N1 (próximo passo)	Compare release, domínio, periodicidade, cliente e resolução posterior.
Limitação da telemetria	DNS sobre HTTPS e cache dificultam observação por resolver.

Comandos de consulta no laboratório

```
getent hosts example.com
resolvectl statistics
```

Log simulado

```
2026-10-31T10:15:12-03:00 srv-app-01 soc-training[1015]: source=linux-lab category="DNS e resolução" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> NXDOMAIN pode ser erro de configuração.

4.16 Pacotes e integridade

O que é: Dpkg/rpm, apt, dnf, repositórios e assinatura.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Binário instalado por gerenciador pode ser alterado depois.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Ferramenta não listada por package manager aparece em /usr/local/bin.
Investigação N1 (próximo passo)	Verifique mudança, hash, autoria, pipeline e uso.
Limitação da telemetria	Ferramenta de verificação depende da distribuição e pacote.

Comandos de consulta no laboratório

```
dpkg -l 2>/dev/null | head
rpm -qa 2>/dev/null | head
```

Log simulado

```
2026-10-31T10:16:12-03:00 srv-app-01 soc-training[1016]: source=linux-lab category="Pacotes e integridade" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Software manual é comum em ambientes reais.

4.17 Persistência e alterações de inicialização

O que é: Systemd, cron, perfis shell, ssh keys e pam.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Mecanismo de autoexecução é dual-use; mudança recente + execução importa.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Unit nova chama executável em pasta de usuário.
Investigação N1 (próximo passo)	Compare baseline, journald, autenticação, pacotes e conexões.
Limitação da telemetria	O N1 identifica e correlaciona; remoção cabe a resposta autorizada.

Comandos de consulta no laboratório

```
find /etc/systemd/system -maxdepth 2 -type f | head
ls -la /etc/cron.d
```

Log simulado

```
2026-10-31T10:17:12-03:00 srv-app-01 soc-training[1017]: source=linux-lab
category="Persistência e alterações de inicialização" user=svc_app result=observed
correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Priorize caminhos com privilégios elevados e pouca justificativa.

4.18 Ferramentas de visibilidade e auditoria

O que é: Auditd, auditctl, ausearch, audit rules e edr linux.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Auditd registra eventos conforme regras; não equivale a capturar tudo.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Alerta de escrita em arquivo sensível surge sem contexto de processo.
Investigação N1 (próximo passo)	Cheque regra ativa, serial do audit, syscall, uid, auid e exe.
Limitação da telemetria	Sem regra correta, determinado acesso pode não ter registro.

Comandos de consulta no laboratório

```
systemctl status auditd --no-pager
ausearch -m USER_LOGIN -ts recent 2>/dev/null | head
```

Log simulado

```
2026-10-31T10:18:12-03:00 srv-app-01 soc-training[1018]: source=linux-lab
category="Ferramentas de visibilidade e auditoria" user=svc_app result=observed
correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Perda de eventos deve ser registrada como risco de cobertura.

4.19 Containers e Linux

O que é: Cgroups, namespaces, overlayfs, docker e logs.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> PID 1 dentro de container não é PID 1 do host.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Processo suspeito aparece em namespace de workload efêmero.
Investigação N1 (próximo passo)	Identifique pod/container, imagem, digest, nó e janela.
Limitação da telemetria	Cloud logs e runtime adicionam fontes além do journal local.

Comandos de consulta no laboratório

```
cat /proc/1/cgroup
findmnt -t overlay
docker ps 2>/dev/null
```

Log simulado

```
2026-10-31T10:19:12-03:00 srv-app-01 soc-training[1019]: source=linux-lab category="Containers
e Linux" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Não derrube workload de produção sem autorização.

4.20 Servidor web e aplicações

O que é: Nginx, apache, access/error logs e reverse proxy.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Status 200 significa resposta HTTP, não exploração confirmada.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Explorações web coincidem com shell novo no servidor.
Investigação N1 (próximo passo)	Correlacione request, worker, processo, arquivo e destino externo.
Limitação da telemetria	IPs de proxy e forwarded headers exigem validação da cadeia.

Comandos de consulta no laboratório

```
systemctl status nginx --no-pager
ls -la /var/log/nginx 2>/dev/null
```

Log simulado

```
2026-10-31T10:20:12-03:00 srv-app-01 soc-training[1020]: source=linux-lab category="Servidor
web e aplicações" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Múltiplas fontes tornam hipótese mais sólida.

4.21 Cloud Linux e agentes

O que é: Cloud-init, metadata, console, iam e registros de nuvem.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Alteração via control plane pode não nascer de sessão SSH.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	SSH key aparece após mudança de metadata de VM.
Investigação N1 (próximo passo)	Cruze audit trail IAM, VM, horários e conteúdo da alteração.
Limitação da telemetria	Logs do provedor e host precisam ser correlacionados.

Comandos de consulta no laboratório

```
systemctl status cloud-init --no-pager
ls /var/log/cloud-init* 2>/dev/null
```

Log simulado

```
2026-10-31T10:21:12-03:00 srv-app-01 soc-training[1021]: source=linux-lab category="Cloud
Linux e agentes" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Incidente de credencial cloud não é só problema do host.

4.22 Malware Linux e indicadores

O que é: Processos, crontab, arquivos, rede, ld_preload e módulos.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> Ferramentas legítimas, compiladores e shells podem ser abusados.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Binário novo + cron + conexões periódicas no mesmo host.
Investigação N1 (próximo passo)	Preserve artefatos e cronologia, avalie impacto e escale.
Limitação da telemetria	Nunca execute arquivo desconhecido para descobrir seu comportamento.

Comandos de consulta no laboratório

```
lsmod | head
env | grep -E "^(LD_|PATH=)"
```

Log simulado

```
2026-10-31T10:22:12-03:00 srv-app-01 soc-training[1022]: source=linux-lab category="Malware
Linux e indicadores" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Não confunda indício com atribuição de família de malware.

4.23 Triagem ponta a ponta

O que é: Fato, hipótese, corroboração, lacuna e decisão.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> A qualidade do ticket depende de evidência verificável e limites explícitos.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Alerta de shell em servidor crítico durante madrugada.
Investigação N1 (próximo passo)	Identifique host, usuário, parent, conexão, baseline e runbook.
Limitação da telemetria	Logs locais podem conter dados sensíveis: sanitizar anexos.

Comandos de consulta no laboratório

```
date -Is
hostname
id
journalctl -n 10 --no-pager
```

Log simulado

```
2026-10-31T10:23:12-03:00 srv-app-01 soc-training[1023]: source=linux-lab category="Triagem
ponta a ponta" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Escalonar com dado útil é melhor do que 20 prints sem contexto.

4.24 Handover, entrevistas e rotina

O que é: Tickets, sla, mudança, responsabilidade e comunicação.

> **O QUE UM N1 REALMENTE PRECISA SABER**
>
> O N1 acompanha o que pode mudar de turno, preservando rastreabilidade.

Leitura de SOC

Pergunta da triagem	Leitura prática
Cenário típico (pode ser benigno)	Caso fica aberto por falta de acesso ao host de origem.
Investigação N1 (próximo passo)	Documente bloqueador, responsável, próxima consulta e horário.

Pergunta da triagem	Leitura prática
Limitação da telemetria	Não reinicie nem isole sistemas críticos sem playbook e autorização.

Comandos de consulta no laboratório

```
printf "Hostname: "
hostname
date -Is
```

Log simulado

```
2026-10-31T10:24:12-03:00 srv-app-01 soc-training[1024]: source=linux-lab category="Handover,
entrevistas e rotina" user=svc_app result=observed correlation=CHG-1042
```

> **NA VIDA REAL**
>
> Handover é transferência de contexto, não repasse de ansiedade.

Laboratórios

Roteiro comum dos 10 laboratórios

> **LABORATÓRIO: Ambiente**
> VM própria/autorizada Debian ou Ubuntu, preferencialmente snapshot.

Preparação

- Registre data, hostname, versão e seu usuário.
- Não reinicie serviços, não apague logs, não altere crontab nem configuração SSH.
- Defina quais canais existem antes do experimento e registre lacunas.

Passo a passo

1. Execute somente a consulta autorizada indicada no laboratório.
2. Salve o resultado com data e hostname no caderno do laboratório.
3. Descreva o que é fato, o que é hipótese e qual dado adicional falta.

Checklist de entrega

Item	Critério de aprovação
Contexto	Sistema, hostname e timezone registrados
Evidência	Saída ou captura com origem e horário
Interpretação	Não confundir evento observado com ataque confirmado
Limitação	Explicar ausências, permissões e cobertura
Próximo passo	Validar mudança e correlação com fonte independente

> **HUMOR DE PLANTÃO**
> Se o comando respondeu "permission denied", ele não está sendo rude. Ele só tem mais governança que muita empresa.

Os laboratórios

Laboratório 1: Reconhecimento e escopo

Objetivo: Colete hostname, distribuição, kernel e timezone; identifique divergências.

```
hostnamectl
cat /etc/os-release
date -Is
timedatectl
```

Laboratório 2: Árvore de processos benignos

Objetivo: Abra um editor ou execute sleep 15 em VM e acompanhe pai, PID e encerramento.

```
ps -eo pid,ppid,user,cmd --forest | head -35
```

Laboratório 3: Serviço conhecido

Objetivo: Documente uma unit instalada, seus overrides e eventos de status.

```
systemctl status cron --no-pager
systemctl cat cron
```

Laboratório 4: Autenticação local

Objetivo: Leia sucessos e falhas recentes sem gerar força bruta ou alterar contas.

```
journalctl _COMM=sshd --since today --no-pager
```

Laboratório 5: Cron de sistema

Objetivo: Compare cron do usuário, cron.d e timers existentes sem mudanças.

```
crontab -l
systemctl list-timers --all
```

Laboratório 6: Acesso a arquivos

Objetivo: Inspecione caminhos, ACL e metadados de arquivos de treinamento.

```
stat /etc/passwd
getfacl /tmp
```

Laboratório 7: Conexão de serviço

Objetivo: Localize sockets e descreva fonte e ausência de visibilidade de processos.

```
ss -tupn
ip route
```

Laboratório 8: Pipeline de logging

Objetivo: Compare logs locais e horário de coleta no SIEM de teste; documente lacunas.

```
journalctl -b -n 30 --no-pager
```

Laboratório 9: Pacotes e baseline

Objetivo: Verifique um software conhecido contra o gerenciador de pacotes.

```
command -v ssh
dpkg -S /usr/bin/ssh 2>/dev/null
```

Laboratório 10: Ticket integrado

Objetivo: Use evidências simuladas de processo, auth e rede para redigir um ticket.

```
date -Is
journalctl -n 10 --no-pager
```

Casos práticos

Roteiro comum dos 8 casos

Em todos os casos, o SIEM gerou uma correlação com severidade alta, mas só uma das fontes estava íntegra. As evidências disponíveis e o raciocínio esperado são os mesmos; muda o cenário e o que validar.

Evidência disponível	Interpretação
Alerta SIEM às 02:14	É detecção, não confirmação
Evento host às 02:15	Exige contexto de usuário, processo e ação
Mudança CHG-1042	Exige consulta ao registro de aprovação
Firewall: conexão permitida	Não comprova payload nem exfiltração
Sem eventos auditd	Avaliar configuração e saúde de coleta

Raciocínio esperado

1. Determine papel do host.
2. Valide timestamp e timezone.
3. Cruze usuário e processo.
4. Confira janelas aprovadas.
5. Procure mudança de arquivo/serviço e impacto.
6. Registre confiança e limite da conclusão.

Resposta fraca	Resposta boa (modelo)
"É malware porque rodou no Linux de madrugada."	Há comportamento fora do padrão em ativo identificado, ainda sem corroboração suficiente para afirmar comprometimento; vou validar: [o que validar, conforme o caso]"

> **MOMENTO SOC**
>
> Se a única prova é o nome do processo, até o backup de domingo vira APT. Segura o relatório, Sherlock.

Os casos

Caso	Cenário fictício	O que validar
1. Usuários, grupos e privilégios	Conta de serviço executa sudo fora da janela de manutenção.	Busque usuário, tty, comando, pam, sudo logs e ticket.
2. Processos, memória e arquivos abertos	Serviço consome CPU e mantém arquivo deleted aberto.	Observe binário, atualização pendente, rota de execução e métricas.
3. Autenticação Linux e PAM	Várias falhas SSH são seguidas de Accepted publickey.	Correlacione origem, fingerprint da chave, usuário e ações posteriores.

Caso	Cenário fictício	O que validar
4. Consultas e correlação temporal	Suspeita de execução às 03:12 com eventos em UTC e local.	Normalize timestamps e compare processo, auth e firewall.
5. Pacotes e integridade	Ferramenta não listada por package manager aparece em /usr/local/bin.	Verifique mudança, hash, autoria, pipeline e uso.
6. Containers e Linux	Processo suspeito aparece em namespace de workload efêmero.	Identifique pod/container, imagem, digest, nó e janela.
7. Malware Linux e indicadores	Binário novo + cron + conexões periódicas no mesmo host.	Preserve artefatos e cronologia, avalie impacto e escale.
8. Mapa mental do Linux no SOC	Servidor de aplicação reiniciou após manutenção; agent reporta novo processo.	Compare janela de mudança, boot id, pai do processo e horário.

Fechamento do Módulo 4

Falsos positivos recorrentes: como confirmar

Alerta / sinal	Explicação possível	Como confirmar
Muitas tentativas SSH	Scanner externo / monitoração	Confirmar sucesso posterior, origem e bloqueio
sudo de madrugada	Automação ou plantão	Validar sudo log, change e origem
cron a cada minuto	Rotina de health check	Identificar dono, script e comportamento
CPU alta	Build, backup, indexação	Cruzar processo, janela e uso de rede
Conexão para IP raro	CDN e fornecedor	Investigar DNS, contrato, processo e bytes
Binário em /tmp	Instalador, script transitório	Validar processo pai, hash e pacote
Service unit alterada	Deploy aprovado	Cruzar diff da unit e pipeline
Chave SSH nova	Onboarding / rotação	Confirmar responsável, fingerprint e mudança
Muitos NXDOMAIN	Erro no resolver	Verificar aplicação, queries e release
File deleted aberto	Atualização de pacote	Relacionar descritor, serviço e restart planejado

Entrevistas SOC N1: resposta fraca x resposta boa

P: Encontrou processo estranho.

Resposta fraca	Resposta boa
É vírus.	Confirmo pai, usuário, binário, horário, assinatura e ações.

P: SSH com muitas falhas.

Resposta fraca	Resposta boa
Brute force invadiu.	Separo falha de sucesso e busco sessão aceita.

P: Cron desconhecido.

Resposta fraca	Resposta boa
Apago imediatamente.	Preservo evidências e valido owner, change e execução.

P: Servidor sem logs.

Resposta fraca	Resposta boa
Não aconteceu nada.	Registro lacuna e verifico auditoria, retenção e forwarding.

P: IP externo raro.

Resposta fraca	Resposta boa
IOC confirmado.	Correlaciono processo, destino, contexto e reputação.

P: sudo executou.

Resposta fraca	Resposta boa
Escalonamento malicioso.	Analiso comando, usuário, TTY, origem e autorização.

P: Existe systemd enabled.

Resposta fraca	Resposta boa
O processo está rodando.	Enabled indica inicialização configurada; confiro active.

P: PID é igual em dois logs.

Resposta fraca	Resposta boa
Mesmo processo.	PID reutiliza; cruzo start time e boot ID.

P: HTTP 200 após tentativa.

Resposta fraca	Resposta boa
Ataque funcionou.	Resposta HTTP não comprova exploração.

P: Host em container.

Resposta fraca	Resposta boa
É o host físico.	Valido namespaces, imagem, runtime e nó.

Exercícios de fixação

1. Encontrou processo estranho. Descreva duas evidências e uma limitação.
2. SSH com muitas falhas. Descreva duas evidências e uma limitação.
3. Cron desconhecido. Descreva duas evidências e uma limitação.
4. Servidor sem logs. Descreva duas evidências e uma limitação.
5. IP externo raro. Descreva duas evidências e uma limitação.
6. sudo executou. Descreva duas evidências e uma limitação.
7. Existe systemd enabled. Descreva duas evidências e uma limitação.
8. PID é igual em dois logs. Descreva duas evidências e uma limitação.
9. HTTP 200 após tentativa. Descreva duas evidências e uma limitação.
10. Host em container. Descreva duas evidências e uma limitação.

Checklist de domínio

- ☐ Consigo ler uma árvore de processos e explicar limites do PID.
- ☐ Sei onde procurar SSH, sudo, cron, systemd e journal.
- ☐ Diferencio autenticação falha de sessão bem-sucedida.
- ☐ Reconheço lacunas de auditd, Sysmon/EDR e SIEM.
- ☐ Sei redigir um ticket com fato, hipótese e risco.

Cheat sheet Linux para SOC N1

Tema	Consulta (somente leitura)
Identidade	`id; whoami`
Sistema	`hostnamectl; uname -a`
Processos	`ps auxf; pstree -ap`
Serviços	`systemctl list-units --type=service`
Logs	`journalctl -b -n 50`
Rede	`ip -br a; ss -tupn`
SSH	`journalctl -u ssh --since today`
Tarefas	`crontab -l; systemctl list-timers`
Pacotes	`dpkg -l / rpm -qa`
Arquivos	`stat; file; sha256sum`

> ⛔ **ATENÇÃO**
> Comandos e nomes de unidades variam por distribuição. Nunca cole logs contendo tokens, credenciais ou dados pessoais em sistemas não autorizados.

Respostas comentadas

Exercício 1. Confirmo pai, usuário, binário, horário, assinatura e ações.

Exercício 2. Separo falha de sucesso e busco sessão aceita.

Exercício 3. Preservo evidências e valido owner, change e execução.

Exercício 4. Registro lacuna e verifico auditoria, retenção e forwarding.

Exercício 5. Correlaciono processo, destino, contexto e reputação.

Exercício 6. Analiso comando, usuário, TTY, origem e autorização.

Exercício 7. Enabled indica inicialização configurada; confiro active.

Exercício 8. PID reutiliza; cruzo start time e boot ID.

Exercício 9. Resposta HTTP não comprova exploração.

Exercício 10. Valido namespaces, imagem, runtime e nó.

Fontes e aprofundamento

- https://www.freedesktop.org/software/systemd/man/latest/journalctl.html
- https://www.freedesktop.org/software/systemd/man/latest/systemctl.html
- https://man7.org/linux/man-pages/
- https://attack.mitre.org/techniques/T1053/003/
- https://attack.mitre.org/techniques/T1098/004/
- https://attack.mitre.org/techniques/T1053/006/

Próximo módulo

Módulo 5: Logs. Aqui terminamos a base de sistemas operacionais; agora começamos a conectar as fontes ao pipeline de investigação.